

Group 3 – Week 3 Vulnerability Assessment Report

Organization: SikaFlow (Fintech Startup)

Assessment Type: Vulnerability Assessment

Date: April 2026

1. Introduction

This report presents the vulnerability assessment conducted on a simulated lab environment as part of Week 3 of the cybersecurity internship program. The objective of this assessment is to identify security vulnerabilities within the target systems, analyze their severity, and evaluate their potential impact on SikaFlow's business operations. This assessment builds on the reconnaissance and enumeration activities conducted in Week 2, where systems, services, and open ports were identified.

2. Objectives

The objectives of this assessment are to:

- Identify vulnerabilities present in the target systems
- Research associated CVEs (Common Vulnerabilities and Exposures)
- Analyze the severity and potential impact of each vulnerability
- Link vulnerabilities to critical assets identified in the asset inventory
- Understand the risks posed to SikaFlow's fintech infrastructure

3. Tools & Resources Used

The vulnerability assessment was conducted using the following tools and resources:

- Nmap – used for network scanning, service detection, and vulnerability identification through the Nmap Scripting Engine (NSE)
- National Vulnerability Database – used to research known vulnerabilities and associated CVEs
- CVE – used to validate and understand identified vulnerabilities

Nmap was used to detect exposed services, while CVE databases were used to analyze the severity and impact of identified vulnerabilities.

4. Target Systems

Asset	IP Address	Description
Windows 11 VM	192.168.56.101	Internal system
Metasploitable 2	192.168.56.102	Vulnerable server

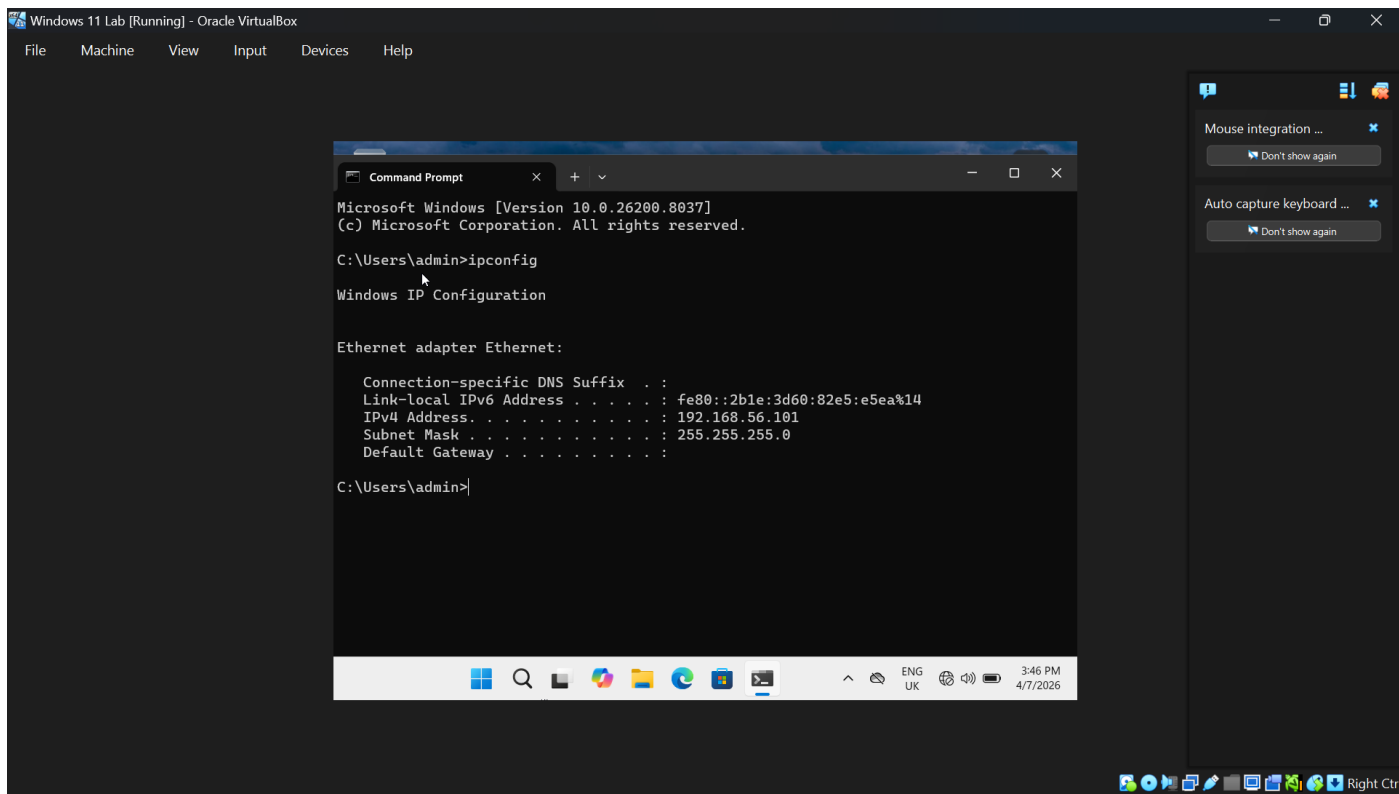


Figure 1: A screenshot of the Windows IP Address (192.168.56.101)

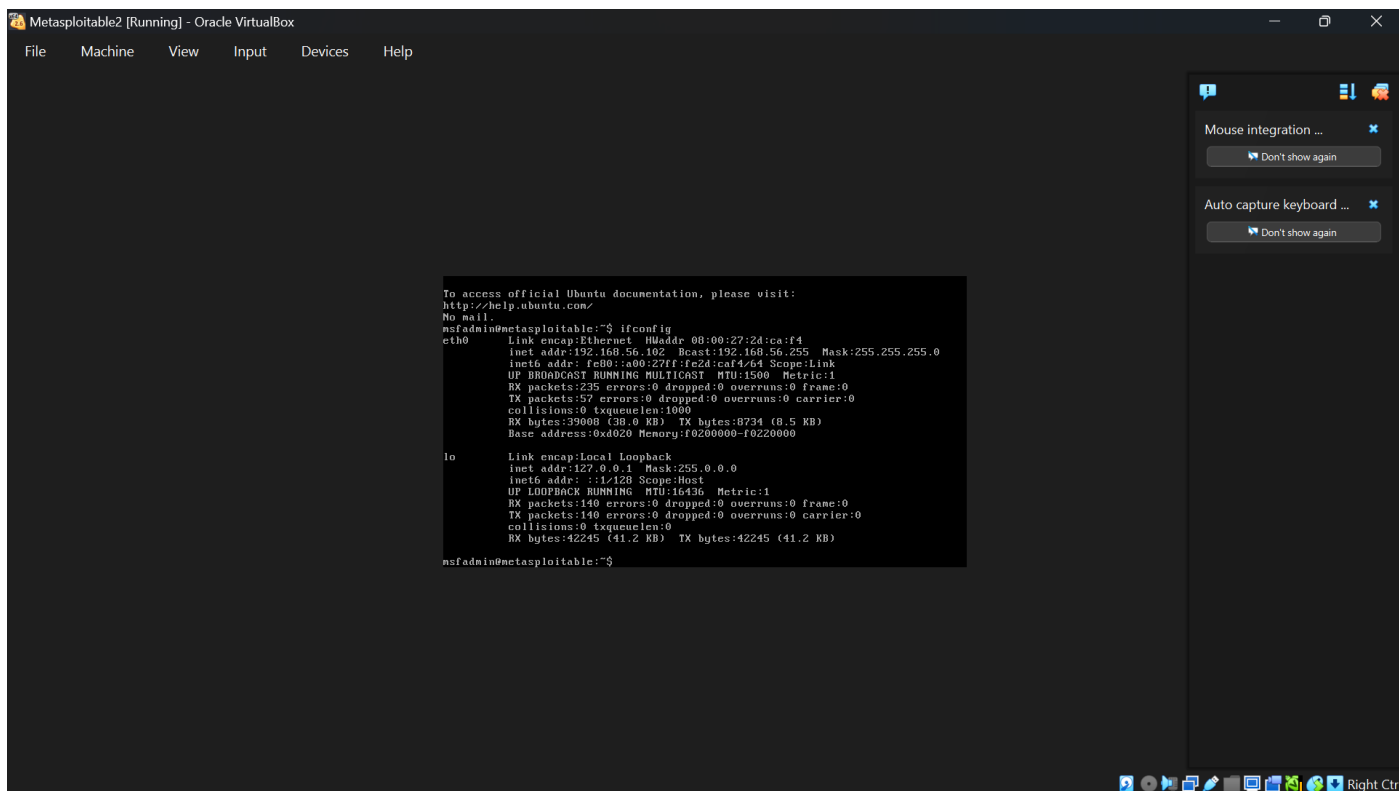


Figure 2: A screenshot of Metasploitable 2 IP Address (inet addr: 192.168.56.102)

5. Scan Results

Vulnerability scans were performed using Nmap with service detection and vulnerability scripts enabled. **The Windows system showed limited exposure, with only essential ports open and most ports filtered, indicating the presence of firewall protection.**

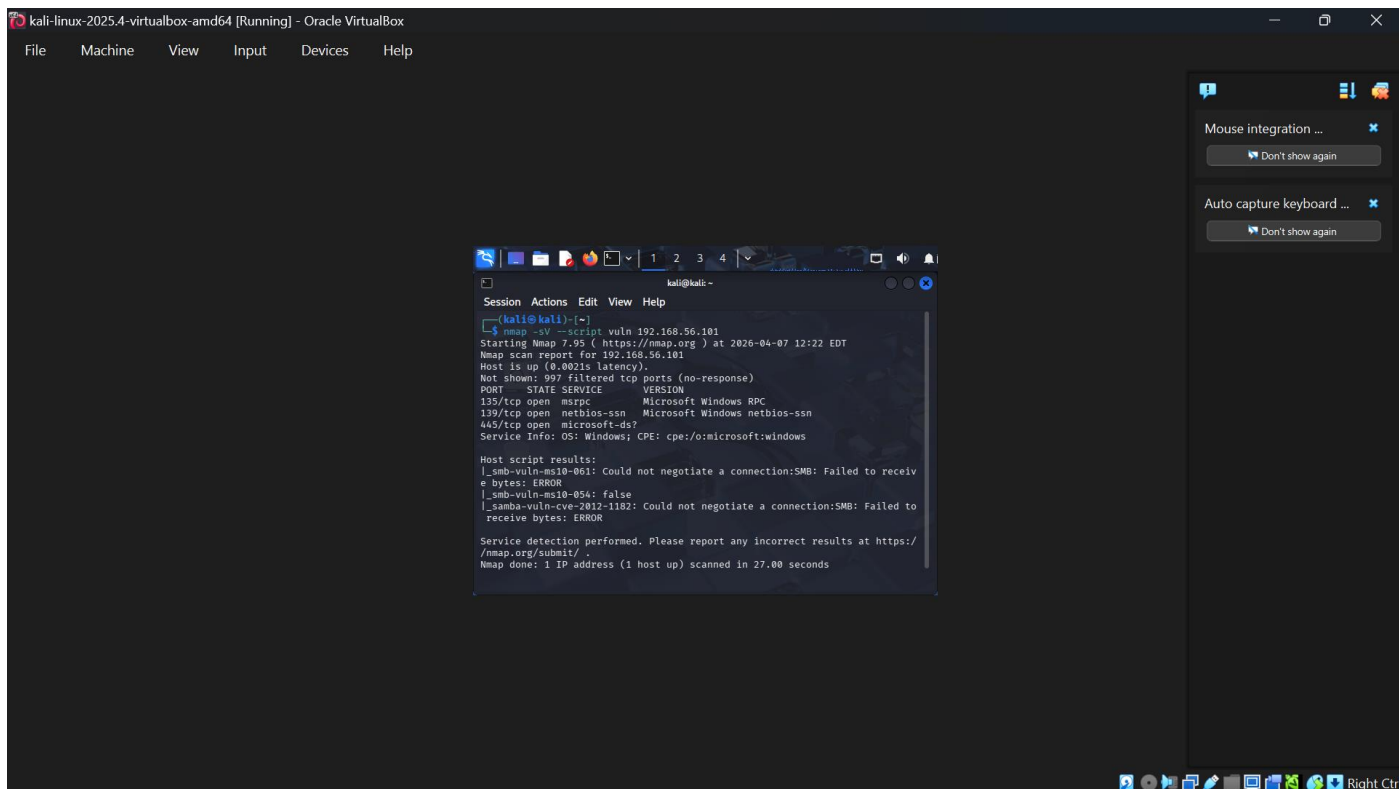


Figure 3: A screenshot of Windows Vulnerability Scan Using Nmap

In contrast, the Metasploitable system revealed numerous open ports and services, significantly increasing its attack surface and exposure to potential attacks.

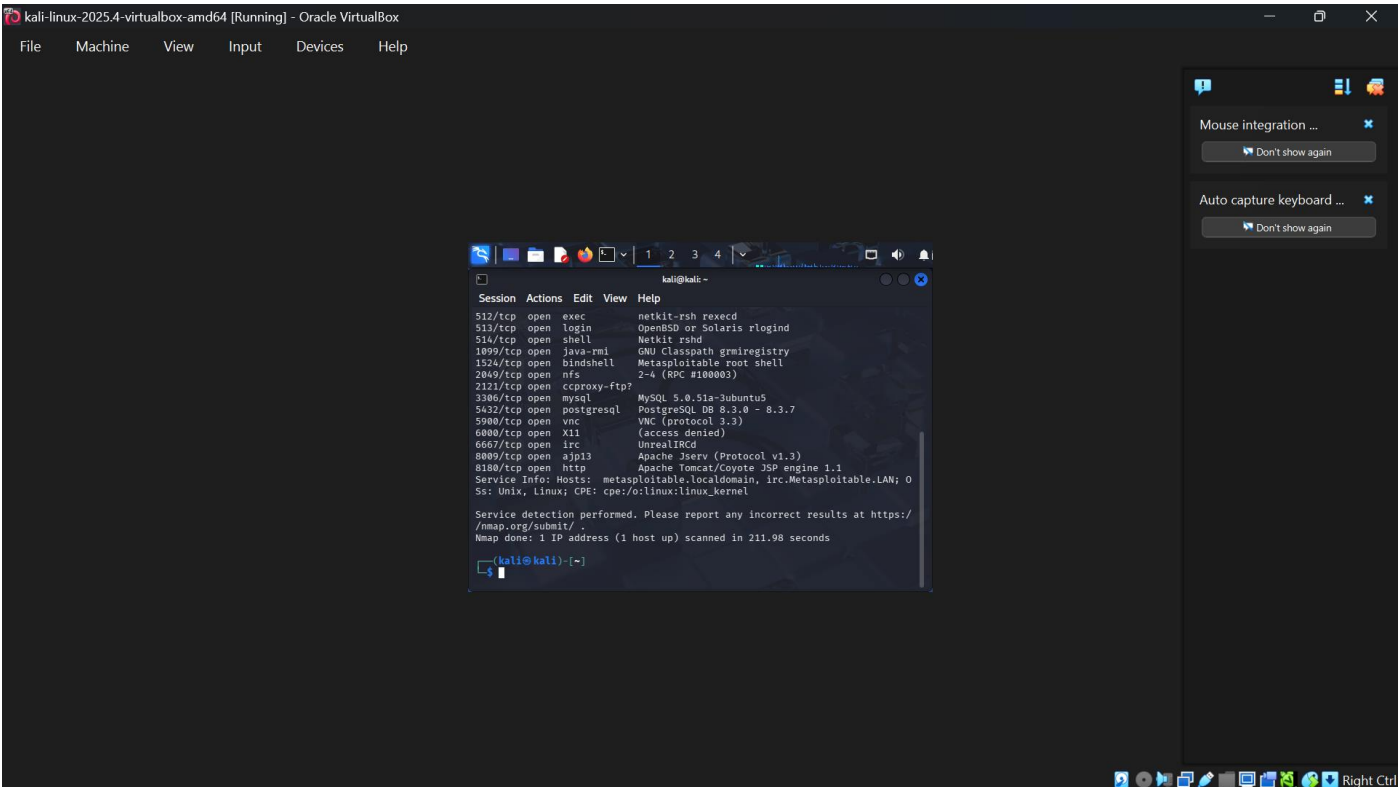
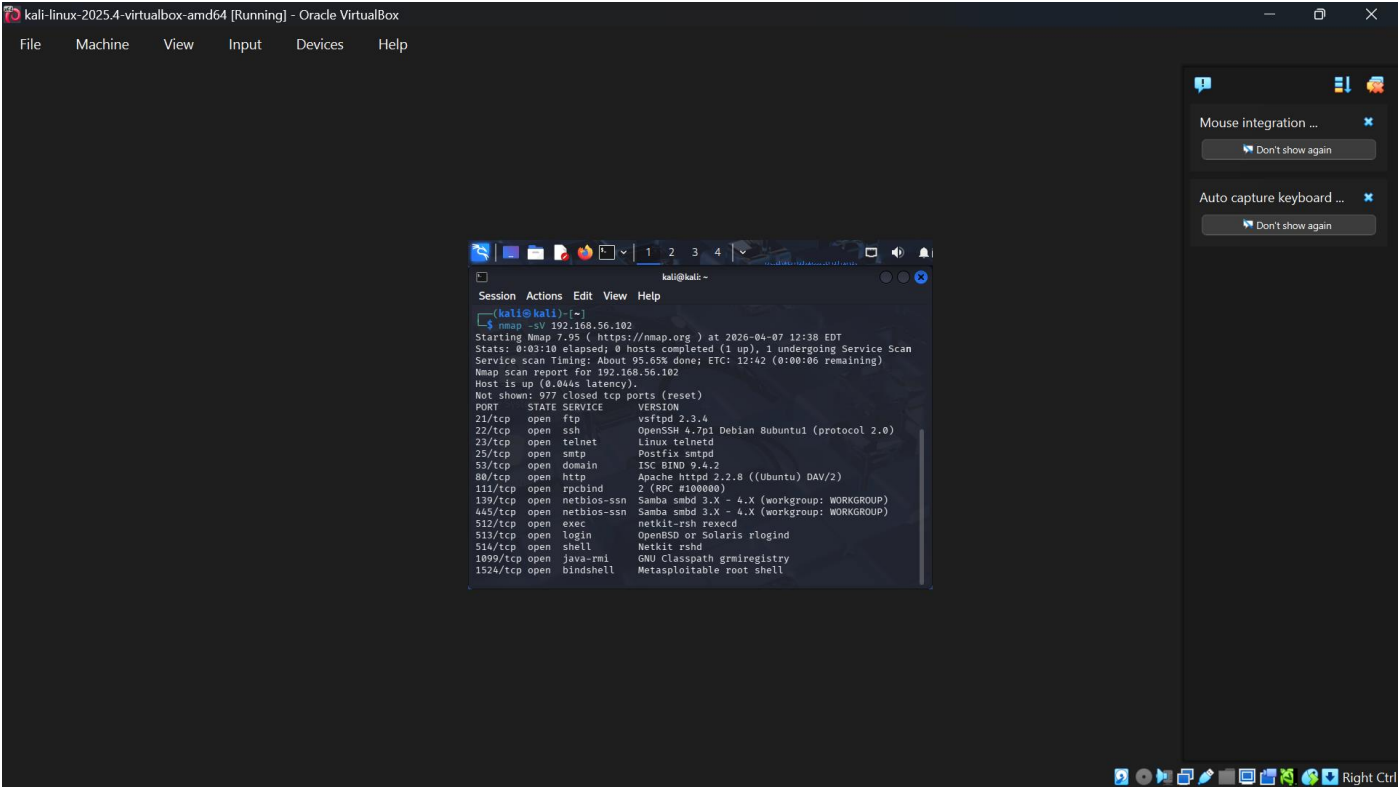


Figure 4: Metasploitable Nmap Scan on Kali Linux shows numerous open ports

6. Identified Vulnerabilities

Summary Table

This summary table consists of several vulnerabilities found during our Nmap scan and connects each vulnerability to the Common Vulnerabilities and Exposures System (CVE) which is a publicly disclosed catalog of information security vulnerabilities maintained by the MITRE Corporation. Each CVE vulnerability is assigned a unique, standardized identifier for a publicly known cybersecurity vulnerability. Also, each vulnerability found severely affects an asset in the company's asset inventory (Week 1).

Vulnerability	CVE	Asset ID	Asset Category	Severity	Business Impact
FTP Backdoor (vsftpd 2.3.4)	CVE-2011-2523	AS-003	Servers (DMZ)	Critical	Full system compromise
Bind Shell (Port 1524)	CVE-1999-1542	AS-001	Core Server	Critical	Root access takeover
MySQL Exposure	CVE-2017-3313	AS-006	Databases	Critical	Data breach
Apache DoS (2.2.8)	CVE-2011-3192	AS-004	APIs	High	Service disruption
Telnet	CVE-2000-0578	AS-017	Network Systems	Critical	Credential theft
Samba (SMB)	CVE-2017-7494	AS-021	Network	Critical	Lateral movement
R Services	CVE-2001-0554	AS-002	Servers	Critical	Unauthorized shell access
SMB (Windows)	N/A	Internal Asset	Network	Medium	Internal exploitation risk

7. Detailed Vulnerability Analysis

FTP Backdoor (Critical)

The FTP service running on the server uses vsftpd 2.3.4, which contains a known backdoor vulnerability (CVE-2011-2523).

This vulnerability allows attackers to gain unauthorized remote access without authentication.

Impact:

An attacker can gain full control of the server, potentially compromising financial systems and sensitive data.

Attack Scenario:

An attacker connects to the FTP service and triggers the backdoor to obtain shell access.

Bind Shell Backdoor (Critical)

A bind shell was discovered on port 1524, allowing direct root access without authentication.

Impact:

This represents complete system compromise. An attacker can execute commands, manipulate financial systems, and install malicious software.

Attack Scenario:

An attacker connects to port 1524 and gains immediate root shell access.

MySQL Database Exposure (Critical)

The MySQL database service is exposed to the network, increasing the risk of unauthorized access.

Impact:

Sensitive financial data and customer records may be accessed or modified, leading to data breaches and regulatory violations.

Attack Scenario:

An attacker performs brute-force attacks or exploits weak credentials to access the database.

Apache Web Server (High)

The Apache server is outdated (version 2.2.8) and vulnerable to denial-of-service attacks (CVE-2011-3192).

Impact:

Attackers can disrupt web services and APIs, affecting financial transactions and user access.

Attack Scenario:

An attacker sends malicious HTTP requests to overwhelm the server.

Telnet (Critical)

Telnet is an insecure protocol that transmits credentials in plaintext which means that the credentials are not encrypted.

Impact:

Attackers can easily intercept usernames and passwords, gaining unauthorized access to internal systems.

Attack Scenario:

An attacker captures network traffic to obtain login credentials.

Samba / SMB (Critical)

The Samba service is outdated and exposed, making it a target for exploitation.

Impact:

Attackers can access shared files or move laterally across systems within the network.

Attack Scenario:

An attacker exploits SMB weaknesses to gain unauthorized access.

R Services (Critical)

Legacy remote services such as rexec and rlogin are insecure and lack encryption.

Impact:

These services allow attackers to gain unauthorized shell access.

Attack Scenario:

An attacker connects directly to these services to execute commands remotely.

Windows SMB Exposure (Medium)

The Windows system exposes SMB and NetBIOS services. Although no known vulnerabilities were detected, these services increase the attack surface.

Impact:

Attackers may use SMB for enumeration or lateral movement within the network.

Attack Scenario:

An attacker attempts to access shared resources or move across systems.

8. Asset Impact Analysis

The identified vulnerabilities directly affect critical assets within SikaFlow's infrastructure, particularly servers and databases responsible for financial operations.

Critical assets such as application servers and databases are at the highest risk, as their compromise could lead to unauthorized transactions, data breaches, and operational disruption.

High-value assets such as APIs and network systems are also at risk, potentially affecting service availability and system integrity.

9. Conclusion

The vulnerability assessment identified multiple critical and high-risk vulnerabilities within the lab environment.

The Metasploitable system demonstrated a highly insecure configuration with several exploitable services, while the Windows system showed a stronger security posture but still presented potential risks.

These findings highlight the importance of continuous vulnerability assessment, proper system configuration, and strong security controls in protecting fintech infrastructure such as SikaFlow.

10. Recommendations

- Disable insecure services such as Telnet and R services
- Patch and update outdated software
- Restrict access to critical services using firewall rules
- Implement strong authentication mechanisms
- Conduct regular vulnerability assessments using tools such as Nmap